

Project 2 – PHI / PII Gateway

Approach Note

System Architecture, Model Selection, Risk Analysis and Compliance Strategy

1. Problem Understanding

The main challenge in this project is not just finding names or other entities in a clinical note.

There are two possible problems:

Under-masking:

If sensitive information is missed, patient information can be exposed.

Over-masking:

If too much information is removed, the clinical meaning of the note can be lost.

So, the system is designed to give more importance to **recall** and then maintain the usefulness of the text through consistent pseudonyms and date shifting.

In simple terms, the goal is:

Protect the patient's information without making the clinical note unusable.

2. Model Selection

Primary Model

The main model selected for the project is:

BioClinical-ModernBERT-base

It has approximately **149 million parameters**, which is within the assessment requirement of less than 1 billion parameters.

The model also supports an **8192-token context window**, which is useful for processing long clinical notes without splitting them into many small sections.

Why this model?

The model was selected because it was trained further on a large amount of biomedical and clinical text.

Its longer context window is also useful because a complete clinical note can be processed together. This reduces problems that can happen when a patient's name or other entity is split between two chunks.

The approach note also references benchmark results where BioClinical-ModernBERT-base reported a **DEID F1 of 82.7**, compared with **74.2 for Bio_ClinicalBERT** under the cited evaluation setup.

Fallback Models

If the main model cannot be used, the planned alternatives are:

- `emilyalsentzer/Bio_ClinicalBERT`
- `microsoft/deberta-v3-base`

These models are also within the required parameter limit.

3. Training Data

The main training dataset selected is:

Technetium-I

It contains around **498k synthetic clinical notes** with approximately **7.74 million PHI spans** across 10 entity types.

The plan is to use around **50k–100k notes** for training and add more examples for categories that are underrepresented.

Additional examples can be generated using **Faker** and template-based data generation.

Additional Dataset

The approach also planned to use the **i2b2/n2c2 2014 de-identification corpus**.

Access to this dataset depends on the required data-use agreement. If access is not received within the planned period, the limitation will be documented instead of treating the dataset as available.

Test Dataset

The test set contains at least **50 held-out clinical notes**.

The test cases are intentionally designed to include difficult situations such as:

- Patient headers
- Signature blocks
- Duplicate information
- Conflicting information

- Difficult or unclear notes
- Synthetic clinical records
- Additional sample clinical data

This helps test the system beyond simple examples.

4. System Architecture

The main processing flow is:

```
graph TD; A[Input Clinical Text] --> B[Text Normalisation]; B --> C[Regex Detection]; C --> D[NER Model]; D --> E[Merge Detected Spans]; E --> F[Date Shifting]; F --> G[Masked Clinical Text]; G --> H[Foundation LLM]; H --> I[LLM Response]; I --> J[Rehydration]; J --> K[Final Response];
```

The system also keeps an **encrypted mapping** between the original values and their pseudonyms.

4.1 FastAPI Service

The gateway is implemented using **FastAPI**.

The main operations are:

```
deidentify(text)
```

and

```
rehydrate(response, mapping)
```

A separate LLM adapter is used for the round-trip demonstration.

4.2 Regex + NER Approach

The system uses more than one detection method.

Regex

Regex is used for structured information where the format is predictable.

Examples include:

- SSN
- Phone numbers
- MRN
- Email
- IP address
- URLs

This gives the system a reliable way to detect these patterns even if the NER model is uncertain.

NER Model

The NER model handles information that depends more on context, such as:

- Names
- Locations
- Organisation names
- Institutional surnames

The detected spans from both methods are then combined.

5. Masking Strategy

The system does not simply replace every sensitive value with the same `[REDACTED]` text.

Instead, it uses **typed pseudonyms**.

Examples:

```
[NAME_1]  
[ORG_1]  
[CONTACT_1]
```

The same original value receives the same pseudonym within the same patient context.

For example, if **John Doe** appears several times, the system can consistently represent it as:

```
[NAME_1]
```

This is useful because the relationship between different parts of the clinical note is still understandable.

Pseudonymisation was chosen instead of simply deleting the information because it keeps the sentence structure and basic context intact.

6. Date and Age Handling

6.1 Date Shifting

Dates are shifted using a patient-specific random offset.

The offset is between:

-364 and +364 days

The same offset is used for the patient's dates so that the relationship between events remains the same.

For example, if one treatment happened three days after another treatment, that **three-day interval remains three days** after shifting.

The actual calendar dates are changed, but the clinical timeline remains useful.

Relative expressions such as:

"two weeks ago"

are kept unchanged because they do not contain an actual calendar date.

6.2 Age Above 89

For patients older than 89, the exact age is not retained.

The age is converted to:

Dates of birth are also handled so that the shifted information does not accidentally reveal an age above the allowed limit.

7. Evaluation Plan

The system is evaluated against multiple baselines.

The planned baselines include:

1. Regex-only approach
2. Microsoft Presidio with spaCy
3. Presidio with an additional de-identification model

The main metrics are:

Entity Precision / Recall / F1

These metrics are measured for each HIPAA category and also as overall micro and macro scores.

Recall and Leak Rate

The main safety metric is **leak rate**.

A document is counted as a leak if at least one sensitive identifier is missed.

Because missing PHI is more serious than incorrectly masking a non-PHI word, the system is tuned with **recall as the first priority**.

Utility Preservation

The system also checks whether the masked text remains useful.

The planned method compares answers to **10 QA questions per note** before and after de-identification.

The difference between the two results is used to measure the effect of masking on clinical information.

Latency

Processing speed is measured using:

- P50 latency
 - P95 latency
 - CPU performance
 - GPU performance
-

8. Recall Priority

The training process also gives more importance to false negatives.

A **class-weighted loss** is used so that missing a sensitive entity has a higher penalty than incorrectly detecting one.

Low-confidence detections can also be sent to a review queue instead of being silently ignored.

This follows the basic safety principle:

Missing PHI = serious problem

while:

Extra masking = inconvenience / possible utility loss

9. Risks and Mitigation

Risk	How It Is Handled
n2c2 dataset access is delayed	Technetium-I is used as the primary dataset
Synthetic data does not represent real clinical text	Adversarial, hand-labelled test cases are used
Medical eponyms are confused with names	Context-based model detection and clinical vocabulary whitelist
Too much information is masked	Utility is measured using QA comparison
Low-confidence detections are missed	Recall-first thresholds and review queue

These risks were considered during the design instead of waiting until the final testing stage.

10. Edge Cases

The system was designed to handle several difficult cases.

10.1 Medical Eponyms

Examples:

- Dr. Parkinson diagnosed Parkinson's
- Mr. Wood admitted to Wood Memorial
- Foley

- Babinski
- Lasix

The system uses context and a clinical vocabulary whitelist to reduce incorrect PERSON detections.

10.2 Hospital Names Containing Surnames

Examples:

- Hollings Cancer Center
- Wood Memorial Hospital

These should be treated as organisations rather than people.

The system uses the **ORG** label and gives preference to organisation spans when the name appears with words such as *Hospital* or *Center*.

10.3 Names That Look Like Common Words

Some names can also be normal words or month names.

Examples:

- May
- Mai
- Winter

The training data includes these cases, and the system uses context and capitalisation to make the decision.

10.4 Hyphenated, Apostrophe and Uppercase Names

Examples:

- O'Brien-Nakamura
- JACKSON

The training data includes different name formats such as hyphenated, apostrophe-based, accented, and uppercase names.

Subtoken labels are also merged when they belong to the same entity.

10.5 Patient vs Provider Names

Both patient and provider names are PHI and therefore need to be protected.

Where the role can be identified, different placeholders can be used:

[NAME]
[PROVIDER]

This keeps some role information available for downstream LLM processing without exposing the actual name.

10.6 Mixed Date Formats

Dates can appear in different formats, for example:

02/11/2024

can have different interpretations depending on the document format.

The system first looks for clear date examples in the document to understand the format.

If a date cannot be parsed safely, it is treated as a date span and masked instead of risking an incorrect date shift.

10.7 Headers, Footers and Tables

Sensitive information can also appear outside the main paragraph.

Examples include:

- Headers
- Footers
- Signature blocks
- Table cells
- Repeated patient banners

The system does not exclude these regions from scanning.

Repeated values are handled through the mapping so that the same value receives a consistent pseudonym.

10.8 OCR and Spelling Errors

Clinical documents can contain OCR errors or misspelled names.

For example:

Smth, John

The training process includes character-level noise, while Regex patterns are also made more flexible for structured identifiers.

10.9 Locations and Addresses

Smaller geographic information and partial addresses need to be handled carefully.

The system uses location labels together with address Regex rules.

State-level information and above can remain because it is allowed under the Safe Harbor approach described in the project.

10.10 Structured Identifiers

The Regex layer handles predictable identifiers such as:

- Phone numbers
- Fax numbers
- Emails
- SSNs
- MRNs
- Account numbers
- Device IDs
- URLs
- IP addresses
- Licence plates

The model is used for less predictable, free-form cases.

11. Out-of-Scope Categories

Some HIPAA categories cannot be handled through a text-only gateway.

These include:

- Biometric identifiers
- Full-face photographs

Since this project processes text, these categories are marked as **not applicable** rather than pretending that the system can process them.

12. Mapping Security

The mapping between the original information and pseudonyms is kept on the server side.

It is:

- Encrypted using Fernet
- Stored with a session-based identifier
- Given a limited lifetime
- Never sent to the LLM

The system also checks that plaintext identifiers are not included in outbound requests.

13. Unexpected Tokens From the LLM

An LLM may sometimes generate a placeholder that was never present in the original input.

For example:

[NAME_99]

If the token does not exist in the mapping, the rehydration process does not try to guess its value.

Instead, it leaves the token unchanged and records a warning.

A final Regex scan is also performed to check whether the response contains patterns such as SSNs or phone numbers.

14. Duplicate and Conflicting Information

Clinical records can sometimes contain different versions of the same information.

For example:

- Whitfield
- Whitmore

If the values are different, the system does not silently assume that they belong to the same person.

Each value is masked separately, and conflicts can be flagged for review.

15. Long Clinical Notes

Long notes can create problems when a model has a small context window.

The selected BioClinical-ModernBERT model supports an **8192-token context**, so the main approach does not require normal chunking for notes within that limit.

Fallback models can use overlapping windows and then reconcile the detected spans.

16. Deterministic Processing

The main model is an **encoder-only model**, not a generative model.

This means the entity detection process is deterministic when the model weights and inputs are fixed.

The system therefore does not depend on a generative model to decide what sensitive information should be masked.

17. HIPAA Category Coverage

The text gateway covers the applicable textual categories using the combination of **NER and Regex**.

These include:

1. Names
2. Geographic information below state level
3. Dates and ages above 89
4. Phone numbers
5. Fax numbers
6. Email addresses
7. SSNs
8. MRNs
9. Health-plan numbers
10. Account numbers
11. Certificate / licence numbers
12. Vehicle / plate information
13. Device IDs / serial numbers
14. URLs
15. IP addresses
16. Other unique IDs / codes

Biometric identifiers and full-face photographs are marked as **N/A** because this implementation is designed for text processing.

18. Development Timeline

The planned development was divided into stages:

Day 0-1

Set up the basic project structure and get the end-to-end flow working with temporary components.

Day 1-3

Build the data pipeline, evaluation harness, and baseline systems.

Day 3-5

Fine-tune the model and tune the detection thresholds.

Day 5-6

Use evaluation results to work on the weakest parts of the system.

Day 6-7

Complete repository cleanup, documentation, failure analysis, demo video, and live round-trip testing.

The failure log was intended to be maintained throughout development rather than written only at the end.

19. Final Approach

The final approach is based on a simple idea:

Use different tools for different types of information.

- **Regex** handles structured identifiers.
- **NER** handles names and context-dependent entities.
- **Pseudonymisation** keeps the text readable.
- **Date shifting** protects calendar information while preserving timelines.
- **Encryption** protects the mapping.
- **Recall-first evaluation** reduces the chance of missing PHI.
- **Review queues** provide a way to handle uncertain cases.

This avoids depending on a single model or a single rule set.

20. Conclusion

The main goal of this approach is to protect sensitive clinical information without removing the useful parts of the medical note.

The design therefore gives priority to **recall and low leakage**, while using pseudonyms and date shifting to retain as much clinical context as possible.

The system combines **BioClinical-ModernBERT, Regex rules, heuristic checks, date shifting, encryption, and context-based handling of difficult cases.**

The approach also clearly defines what the text gateway can and cannot handle. Text-based PHI can be processed through the gateway, while non-text categories such as biometrics and full-face photographs remain outside the scope of this implementation.